ТРЕБОВАНИЯ ПО ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ КТК ЭЛОУ-АВТ

Типы обрабатываемых данных и обоснование уровня защиты

Категории обрабатываемых данных

Категория	Состав данных	Уровень чувствительности
Производственные данные (технологические)	Параметры установки ЭЛОУ-АВТ (давление, температура, расход, уровни); конфигурации оборудования; технологические регламенты	**Критичный** (98-ФЗ ст. 3)
Данные цифрового двойника	Математические модели, параметры ректификации, гидравлики, теплообмена	**Критичный** (ГК РФ ст. 1465, 98-ФЗ, ст.3)
Персональные данные	ФИО, должность, табельный номер, результаты обучения, оценки квалификации	**Критичный** (152-ФЗ ст.3)
Данные сессий обучения	Логи действий, время реакции, последовательность команд, ошибки	**Высокий** (152-ФЗ, ст. 3)
Данные ИИ-модуля	Весовые коэффициенты, архитектура моделей, сценарии обучения	**Критичный** (ГК РФ ст. 1225, 98-ФЗ ст. 3)
Аутентификационные данные	Учётные записи, хеши паролей, сертификаты	**Критичный** (152-ФЗ, Приказ ФСТЭК №31 п.1)

Обоснование уровня защиты

Установка ЭЛОУ-АВТ относится к объектам **критической информационной инфраструктуры (КИИ)** согласно 187-ФЗ. КТК содержит:

- коммерческую тайну предприятия (технологические параметры и цифровой двойник);
- персональные данные (регулируются 152-ФЗ);
- интеллектуальную собственность (ИИ-алгоритмы).

На основании этого системе присваивается **1-й (высший) класс защищённости** (приказ ФСТЭК №31).

Нормативная база:

- 152-ФЗ «О персональных данных»
- 187-ФЗ «О безопасности критической информационной инфраструктуры»
- Приказ ФСТЭК №31 (требования к АСУ ТП)
- ГОСТ Р 59793-2021 (стадии создания АС)
- ГОСТ Р 57700.37-2021 (цифровые двойники)
- ГОСТ Р МЭК 61511-1-2018 (функциональная безопасность)
- ГОСТ Р 56939-2024 (безопасная разработка ПО)

Детальные требования ИБ к компонентам

Программные компоненты

Компонент	Требования
СУБД	Шифрование хранения (AES-256); RBAC; журнал аудита; резервное копирование
Прикладное ПО тренажёра	Многофакторная аутентификация; TLS 1.3; валидация входных данных; защита от обратного инжиниринга
ИИ-модуль	Изолированное выполнение (контейнер); контроль целостности моделей (SHA-256); логирование предсказаний
ОС АРМ	ОС Astra Linux Special Edition (сертифицирована ФСТЭК); подсистема безопасности PARSEC, реализующая мандатное управление доступом (МРД) и мандатный контроль целостности (МКЦ)

Аппаратные компоненты

Компонент	Требования
Серверы	Выделенные стойки; TPM 2.0; аппаратное шифрование дисков
АРМ операторов	Блокировка USB (кроме клавиатуры/мыши); биометрия или смарт-карты
Сетевое оборудование	NGFW, IDS/IPS, VPN с MFA

Сетевая сегментация

- **VLAN 1** – серверная инфраструктура (БД, ядро КТК, ИИ-модуль)
- **VLAN 2** – АРМ обучаемых
- **VLAN 3** – АРМ инструкторов и администраторов
- **VLAN 4** – управление (out-of-band)
- **DMZ** – внешние интерфейсы (при необходимости)

Модель угроз и источники рисков

Перечень актуальных угроз

Вид угрозы	Конкретные угрозы
Конфиденциальность	НСД к серверу и БД; перехват трафика; инсайдерская угроза
Целостность	Подмена логов и результатов; манипуляция моделью; компрометация ИИ (отравление, adversarial attacks); фальсификация оценок
Доступность	DoS/DDoS; шифровальщики; отказ оборудования
Специфические для КТК	Подмена сценариев обучения; манипуляция временными метками; компрометация эталонных сценариев

Источники угроз

- Внешние злоумышленники
- Внутренние нарушители
- Вредоносное ПО
- Ошибки администрирования

Обоснование выбора мер

Меры выбраны на основе анализа рисков по ГОСТ Р ИСО/МЭК 27001 и требований ФСТЭК к АСУ ТП.

9.4. Технические решения и разграничение доступа

9.4.1. Решения на уровне ОС и сети

Уровень	Конкретное решение
ОС	Astra Linux Special Edition / РЕД ОС; отключение неиспользуемых служб; SELinux/AppArmor; контроль целостности (AIDE); auditd
Сеть	NGFW (UserGate / InfoWatch); SIEM (MaxPatrol / RuSIEM / «СерчИнформ»); DLP («СерчИнформ КИБ» / Solar Dozor); IDS/IPS на базе NGFW; VPN с MFA

9.4.2. Ролевая модель доступа (RBAC)

Роль	Разрешённые действия	Запрещённые действия
Обучаемый	Запуск сценариев; просмотр своих результатов	Изменение конфигурации; доступ к чужим данным
Инструктор	Создание/редактирование сценариев; назначение тренировок; просмотр результатов всех; отчёты	Изменение системных настроек; доступ к моделям ИИ

Администратор	Управление пользователями; техобслуживание; обновление ПО; просмотр техлогов	Изменение результатов обучения; доступ к персональным данным без нужды
Аудитор	Чтение журналов аудита; отчёты по безопасности	Любые изменения
Разработчик сценариев	Создание сценариев; доступ к мат. модели	Доступ к персональным данным

9.4.3. Дополнительные меры

- Таймаут сессии – 15 минут
- Пароль: минимум 12 символов, сложность, смена 90 дней
- MFA – для инструкторов и выше
- Принцип наименьших привилегий

9.5. Безопасность ИИ, мониторинг и реагирование на инциденты

9.5.1. Требования к защите ИИ-алгоритмов

- Хранение весов моделей в зашифрованном виде
- Контроль целостности (хеширование SHA-256)
- Изолированное выполнение (Docker + AppArmor)
- Валидация входных данных (защита от adversarial attacks)
- Версионирование моделей с цифровой подписью
- Анонимизация обучающих выборок
- Дифференциальная приватность
- Федеративное обучение (при необходимости)
- Объяснимость решений (логирование с обоснованием)
- Human-in-the-loop для критических оценок

9.5.2. Мониторинг и аудит (SIEM + UEBA)

- Централизованный сбор логов (MaxPatrol SIEM)
- Корреляция событий:

    - множественные неудачные входы → brute force
    - доступ в нерабочее время → аномалия
    - массовое скачивание → утечка
    - изменение эталонных сценариев → саботаж
- Профили нормального поведения (UEBA)
- Risk scoring
- Real-time dashboard и алерты
- Автоматическая блокировка при атаке

9.5.3. Классификация инцидентов

Уровень	Описание	Примеры
1 (Низкий)	Единичные нарушения	Неудачные входы; незначительные отклонения
2 (Средний)	Подозрительная активность	Доступ к несанкционированным ресурсам; аномалии в результатах
3 (Высокий)	Реализованная угроза	Успешный НСД; подмена данных; компрометация учётки
4 (Критический)	Системная катастрофа	Массовая утечка; отказ системы; компрометация ИИ

9.5.4. Процедуры реагирования

- **Уровень 1** – фиксация, ежедневный отчёт администратору.
- **Уровень 2** – уведомление ИБ за 1 час; ограничение прав; расследование 24 часа.
- **Уровень 3** – уведомление CISO; изоляция; блокировка учёток; активация CSIRT; восстановление из бэкапов; уведомление руководства за 4 часа.
- **Уровень 4** – активация DRP; переход на резервный ЦОД; уведомление руководства за 30 мин; привлечение внешних экспертов; уведомление регуляторов (при утечке ПД); post-mortem.

9.5.5. Восстановление

- Сохранение доказательств (forensics)
- Анализ первопричины (root cause)
- Устранение уязвимостей

- Обновление политик и процедур (lessons learned)
- Дополнительное обучение персонала

9.6. Перечень разрабатываемых документов

Политики и регламенты:

1. Политика информационной безопасности КТК
2. Регламент управления доступом
3. Инструкция по реагированию на инциденты
4. Политика резервного копирования и восстановления
5. Регламент обновления ПО
6. Инструкция по безопасной разработке сценариев

Техническая документация:

1. Архитектура безопасности системы
2. Схема сетевой инфраструктуры с зонами безопасности
3. Матрица доступа (роли × ресурсы)
4. Реестр угроз и мер защиты
5. План непрерывности бизнеса (BCP)

Данный раздел разработан в соответствии с требованиями 152-ФЗ, 187-ФЗ, приказа ФСТЭК №31, ГОСТ Р 59793-2021, ГОСТ Р 57700.37-2021, ГОСТ Р МЭК 61511-1-2018, ГОСТ Р 56939-2024 и отраслевых стандартов.

Общие замечания по ролевой модели

В ФТ заявлены три роли:

- **Оператор** (обучаемый)
- **Руководитель** (инструктор/менеджер)
- **Консультант поддержки** (администратор/настройщик)

В соответствии с лучшими практиками ИБ и требованиями ФСТЭК рекомендуется добавить как минимум **роль Аудитора** (только чтение логов, без права изменений) и, **роль Разработчика сценариев** (создание сценариев без доступа к

персональным данным и результатам). В текущей модели отсутствует разделение между администрированием системы и настройкой сценариев — это нарушает принцип «разделения обязанностей» (SoD). Рекомендуется уточнить роли и соответствующие им права.